

## 06. テスト仕様書

Version 1.4 / 2026-08-18

### 1. テスト方針

実験導入フェーズであることを踏まえ、テストは「壊れると営業が止まる箇所」と「壊れても気付けない箇所」に絞って実施する。網羅率を追わない代わりに、下記の受入テストは導入前に必ず全件実施する。

| 種別       | 対象                   | 実施方法                   | 必須  |
|----------|----------------------|------------------------|-----|
| 受入テスト    | 機能要件 FR-01～FR-15     | 実機(スマホ+タブレット)による手動確認   | 必須  |
| セキュリティ確認 | なりすまし・権限・鍵の露出        | 手動 + ブラウザ開発者ツール        | 必須  |
| 自動テスト    | セッション検証・ステータス遷移・金額計算 | pytest(バックエンド単体)       | 推奨  |
| 負荷テスト    | —                    | 実施しない(想定同時利用者が7卓程度のため) | 対象外 |

#### 自動テストを最小限にする判断

実験導入段階では仕様変更が頻繁に発生するため、UIの自動テストは維持コストが利益を上回る。一方、セッション検証・ステータス遷移・金額計算の3点は、「壊れていても画面上は正常に見えてしまう」ためpytestでの自動化を推奨する。

#### 現在の実施状況(V1.3時点)

バックエンド・フロントエンドの実装は未着手のため、本書は実装完了後もあらためて全件実施する必要がある。ただし、プロトタイプ(prototype/index.html)は実際の画面遷移・状態管理をJavaScriptで再現しているため、画面側のロジックに限りプロトタイプに対して先行実施した。結果は2章末の一覧を参照。 - 実施できたもの: 顧客・スタッフ双方のUI操作(AT-01～AT-27)、V1.2で追加した呼出・価格更新・ポーリング関連(AT-29・AT-32～AT-42)。ヘッドレスブラウザによる自動実行で、クロック操作により経過時間の演出(AT-33)も検証した。 - 対象外(N/A): サーバー側のみで判断できるもの(AT-13・14・28・31・44・45、ST-01～12)、複数端末でのセッション共有(AT-10・12)、ページ再読込での永続化(AT-09・11 — プロトタイプはsessionStorageを持たない単純なモックのため)、実ネットワーク断(AT-43)。これらは実装後にあらためて実施する。 - この先行実施で2件の不具合を発見し、プロトタイプを修正済み。詳細は2.1節。

#### 1.1 プロトタイプ先行実施で見つかった不具合(修正済み)

設計書(01・03・04)に書かれている仕様そのものは正しかったが、プロトタイプの実装がそれと食い違っていた。設計書ではなくプロトタイプ側を仕様に合わせて修正した。

| # | 内容                                                                                                                                      | 気づいたテスト             | 修正                                           |
|---|-----------------------------------------------------------------------------------------------------------------------------------------|---------------------|----------------------------------------------|
| 1 | 会計クリア直後の古い画面が、本来出るべき「QRコードを読み直してください」(SESSION_EXPIRED)ではなく、「ただいまご利用いただけません」(TABLE_NOT_ACTIVE)になっていた。2つの判定の順序が逆で、「未開栓」の判定が常に先に評価されていたため。 | AT-27               | 判定順序を入れ替え、「このタブが過去にセッションを保持していたか」を先に見るようにした。 |
| 2 | メニュー価格・手入力の価格が、空欄のまま確定すると0円になり、負値は弾かれるが小数はそのまま通ってしまっていた。設計書([04]3.9・3.11)は「負値・非整数は400」としているのに、実装は非整数チェックをしていなかった。                       | AT-39(価格更新)、手入力の価格欄 | 「0以上の整数」を厳密にチェックし、不正な入力直前の価格に戻すよう修正した。       |

このほか、テストとは別に見つけた改善点として、シナリオ帯(画面上部の①～⑤の案内)が「今その状態の卓があるか」を見ていたため、会計クリアした瞬間に①・④のチェックが外れてしまう問題があった。注文・提供済のチェックは明細が残るため外れないのに、開栓・呼出・会計クリアだけ卓の状態が可逆で外れてしまうという一貫性の欠如だったため、いずれも「このセッション中に一度でも経験したか」に統一した。

## 1.2 プロトタイプでの実施結果一覧

| ID範囲        | 内容                                                     | 結果                                                                                                               |
|-------------|--------------------------------------------------------|------------------------------------------------------------------------------------------------------------------|
| AT-01～AT-08 | 顧客: メニュー表示・価格・カート・注文送信・二重送信防止・履歴表示・準備中/提供済の分離          | 全件PASS                                                                                                           |
| AT-13～AT-15 | スタッフ: ログイン・フロアマップ表示                                    | N/A(V1プロトタイプにログイン画面なし。実装後に実施)                                                                                    |
| AT-16～AT-27 | スタッフ: 開栓・重複開栓・未提供リスト・提供済/Undo/取消・手入力・品切れ・会計クリア・セッション失効 | 全件PASS(1件不具合を発見・修正 → AT-27)                                                                                      |
| AT-28       | 日次バッチ                                                  | N/A(プロトタイプはバッチを再現しない)                                                                                            |
| AT-29～AT-36 | 呼出(用件選択・幕等性・一覧の並び・経過時間の強調・解除・会計クリア連動)                  | AT-29・32～36はPASS。AT-30・31はサーバー側の幕等性検証でありAPI実装後に実施(UIは呼出中の再呼出自体を出さない設計)                                           |
| AT-37～AT-40 | メニュー価格更新・スナップショット・入力検証・入力中の保護                          | 全件PASS(1件不具合を発見・修正 → AT-39相当)                                                                                    |
| AT-41～AT-42 | ポーリングの非表示時停止・復帰                                        | 全件PASS                                                                                                           |
| AT-43       | 通信失敗時の案内                                               | N/A(プロトタイプは実通信を行わないモック)                                                                                          |
| AT-44～AT-45 | JWT有効期限                                                | N/A(プロトタイプに認証なし)                                                                                                 |
| AT-46～AT-53 | 空席状況(表示・開栓/会計クリア連動・呼出理由の非表示・情報漏洩なし)                    | AT-46～49・51はPASS。AT-50は当初FAILする実装だった(内部ポーリングが裏で動き続けていた)が、原因を特定し修正してPASS。AT-52(レート制限)・AT-53(認証ヘッダーの無視)はサーバー実装後に実施 |
| ST-01～ST-14 | セキュリティ確認全般                                             | N/A(バックエンド・DB・鍵管理が実在しないため、実装後に全件実施)                                                                              |

自動化したテストスクリプト(Playwright)は保守用の参考として **prototype/** 配下ではなく開発メモに残し、実装後のE2Eテストの土台として流用できる。

## 2. 受入テストケース(顧客機能)

| ID    | 対応    | 手順                      | 期待結果                                            |
|-------|-------|-------------------------|-------------------------------------------------|
| AT-01 | FR-01 | 開栓済みの卓T1のQRコードをスマホで読み取る | T1のメニュー画面が表示され、品切れ商品が表示されない                     |
| AT-02 | FR-01 | 未開栓の卓T3のQRコードを読み取る      | 「ただいまご利用いただけません」の案内が表示され、注文できない                 |
| AT-03 | FR-01 | メニューの価格表示を確認する          | 店頭メニューと同じ金額が表示されている(例: ドリップコーヒー HOT 600円)       |
| AT-04 | FR-02 | 商品を2点カートに追加し、注文を送信する    | 送信が成功し、注文履歴画面へ遷移する                              |
| AT-05 | FR-02 | 注文送信ボタンを連打する            | 二重に注文が登録されない                                    |
| AT-06 | FR-03 | 注文履歴を表示する               | 注文した商品と参考小計(税込)が表示され、チャージを含む旨と会計はレジで確定する旨の注記がある |
| AT-07 | FR-03 | スタッフが提供済にした後、8秒以上待つ     | 履歴画面の表示が「準備中」から「提供済」に自動で変わる                     |
| AT-08 | FR-03 | 準備中と提供済の明細が混在する状態で履歴を開く | 準備中が上部に、提供済が「提供済み(会計履歴)」として下部にまとまって表示される        |
| AT-09 | FR-03 | 全ての注文が提供済の状態で履歴を開く      | 「準備中のご注文はありません」が表示される                           |

| ID    | 対応    | 手順                       | 期待結果                         |
|-------|-------|--------------------------|------------------------------|
| AT-10 | FR-04 | 「スタッフを呼ぶ」から用件を選ぶ         | ボタンが「(用件) 呼出中…」に変わり、連打できない   |
| AT-11 | FR-03 | 注文履歴画面をリロードする            | ログイン等を求められず、同じ履歴が再表示される      |
| AT-12 | FR-01 | 同じ卓のQRを2台目のスマホで読み取り、注文する | 2台目の注文も同じ伝票に追加され、双方の履歴に表示される |

### 3. 受入テストケース(スタッフ機能)

| ID    | 対応    | 手順                      | 期待結果                                      |
|-------|-------|-------------------------|-------------------------------------------|
| AT-13 | FR-05 | 正しいID/パスワードでログインする      | ダッシュボードが表示される                             |
| AT-14 | FR-05 | 誤ったパスワードでログインする         | ログインできず、エラーが表示される                         |
| AT-15 | FR-06 | ダッシュボードを表示する            | 7卓すべてが実際の座席レイアウトどおりに配置されている               |
| AT-16 | FR-07 | 空席の卓を開栓する               | 卓がオレンジ(使用中)になり、QR読取で注文可能になる               |
| AT-17 | FR-07 | 既に使用中の卓を、別端末から同時に開栓する   | 「既に開栓済みです」と表示され、伝票が二重に作られない               |
| AT-18 | FR-08 | 客が注文した後、4秒以上待つ          | 未提供リストに該当明細が受付順で表示される                     |
| AT-19 | FR-08 | 未提供明細の「提供済」をタップする       | 提供済表示に変わり、客の履歴画面にも反映される                   |
| AT-20 | FR-08 | 提供済にした明細の「戻す」をタップする     | 未提供状態に戻る                                  |
| AT-21 | FR-09 | 未提供明細の「 」で取消する          | 明細が取消され、参考小計から除外される                       |
| AT-22 | FR-10 | 手入力で「テスト商品 1,000円」を追加する | 該当卓の伝票に追加され、客の履歴にも表示される                   |
| AT-23 | FR-11 | 品切れ・価格管理で商品を品切れに設定する    | 客のメニュー画面から該当商品が消える                        |
| AT-24 | FR-11 | 品切れを解除する                | 客のメニュー画面に再表示される                           |
| AT-25 | FR-07 | 使用中の卓を会計クリアする           | 確認ダイアログの後、卓が「空席」に戻り、呼出表示も消える              |
| AT-26 | FR-07 | 未提供の明細が残る卓を会計クリアしようとする  | 未提供の件数が警告として表示される                         |
| AT-27 | FR-07 | 会計クリア後、客が同じ画面で注文を試みる    | 「QRコードを読み直してください」と表示され、注文できない             |
| AT-28 | FR-12 | 卓を開栓したまま日次バッチを実行する      | 対象卓が空席に戻り、checkout_staff_id がNULLのまま記録される |

### 4. 受入テストケース(V1.2 追加分)

呼び出し・価格更新・通信制御は今回のレビューで追加された機能であり、重点的に確認する。

| ID    | 対応    | 手順                | 期待結果                                               |
|-------|-------|-------------------|----------------------------------------------------|
| AT-29 | FR-13 | 用件を選んで呼び出す        | orders.call_reason が更新され、call_events に1行 INSERTされる |
| AT-30 | FR-13 | 呼び出し中に別の用件で再度呼び出す | call_reason が上書きされ、call_events は増えない(幕等)           |
| AT-31 | FR-13 | reason に列挙値以外を送る  | 400 (VALIDATION_ERROR) が返る                         |
| AT-32 | FR-13 | ダッシュボードを開く        | 上部に呼び出し一覧が表示され、経過時間の長い順に並ぶ                         |
| AT-33 | FR-13 | 呼び出しから1分・3分経過させる  | 経過時間に応じて背景の強調が段階的に強くなる                             |

| ID    | 対応     | 手順                          | 期待結果                                                   |
|-------|--------|-----------------------------|--------------------------------------------------------|
| AT-34 | FR-13  | 会計以外の用件を「対応しました」で解除する       | is_calling=false・resolved_at 設定・卓はActiveのままで、客は追加注文できる |
| AT-35 | FR-13  | お会計の用件の行を確認する               | 「対応しました」ではなく「確認する」が表示され、会計クリアへ誘導される                    |
| AT-36 | FR-13  | 呼び出し中の卓を会計クリアする             | is_calling=false かつ未解決の call_events が解消される             |
| AT-37 | FR-14  | STF-004 から価格を更新する           | products.price が更新され、顧客メニューに反映される                      |
| AT-38 | FR-14  | 注文済み明細がある商品の価格を更新する         | order_items.price は変わらず、参考小計も変動しない                     |
| AT-39 | FR-14  | 負値・非整数の価格を送る                | 400 (VALIDATION_ERROR) が返る                             |
| AT-40 | FR-14  | 価格入力欄に入力中(未確定)の状態でのポーリングが走る | 入力中の値が消えない                                             |
| AT-41 | NFR-08 | 画面を非表示にする(タブ切替・画面ロック)       | ポーリングが停止し、リクエストが発生しない                                  |
| AT-42 | NFR-08 | 画面を再表示する                    | 1回だけ即時取得し、以降は通常間隔へ戻る                                   |
| AT-43 | —      | 注文送信時にネットワークを遮断する           | 口頭依頼を促す文言を表示し、自動リトライしない                                |
| AT-44 | NFR-03 | JWT発行から12時間経過後にスタッフAPIを呼ぶ   | 401 (UNAUTHORIZED) を返しログイン画面へ遷移する                      |
| AT-45 | NFR-03 | JWT発行から11時間59分でスタッフAPIを呼ぶ   | 正常に応答する                                                |

#### AT-38 は特に重要

価格改定と会計金額の整合性に直結する。ここが壊れていると、営業中にGUESTジンの価格を変えた瞬間、既に注文済みの他卓の伝票金額まで書き換わる。画面上は自然に見えてしまうため、必ず実データで確認すること([08]7章 不変条件6・10)。

## 5. 受入テストケース(V1.3 追加分・空席状況)

空席状況(PUB-001)は認証なしで誰でもアクセスできる新しいエンドポイントであるため、機能面に加えて情報漏洩がないことの確認を必須とする。

| ID    | 対応     | 手順                                                     | 期待結果                                                                  |
|-------|--------|--------------------------------------------------------|-----------------------------------------------------------------------|
| AT-46 | FR-15  | ログイン・QR読取のいずれもせずに /vacancy を開く                         | 卓ごとの空席状況が表示される                                                        |
| AT-47 | FR-15  | ある卓を開栓してから /vacancy を開く                                | その卓が「ご利用中」と表示される                                                      |
| AT-48 | FR-15  | その卓を会計クリアしてから /vacancy を再取得する                          | その卓が「空いています」に戻る(20秒以内)                                                |
| AT-49 | FR-15  | 卓を呼出中の状態にする                                            | /vacancy 側の表示は「ご利用中」のままで、呼出中であることは判別できない                              |
| AT-50 | FR-15  | /vacancy の画面を非表示にする                                    | ポーリングが停止する(4.1節と同じ共通フックの挙動)                                           |
| AT-51 | NFR-14 | GET /api/v1/public/availability のレスポンスを確認する            | session_token / order_id / is_calling / call_reason / 金額のいずれのキーも含まれない |
| AT-52 | NFR-04 | GET /api/v1/public/availability を1分間に31回以上呼ぶ           | 31回目以降に 429 (RATE_LIMITED) が返る                                        |
| AT-53 | —      | Bearer / X-Session-Token を付けて /public/availability を呼ぶ | 認証情報の有無にかかわらず同じ結果が返る(付与しても優遇・拒否されない)                                  |

### AT-51 は特に重要

このエンドポイントはログイン不要で誰でも叩けるため、レスポンスに1つでも余分なフィールドが混入すると、その場で全世界に漏洩する。実装時は3.13節のとおり、専用の絞り込みスキーマを経由しているかをコードレビューで確認すること。

## 5.1 プロトタイプ実装で見つけた不具合(修正済み)

| # | 内容                                                                                                                     | 気づいたテスト             | 修正                                                 |
|---|------------------------------------------------------------------------------------------------------------------------|---------------------|----------------------------------------------------|
| 1 | <code>/vacancy</code> を単独で開いたとき、本来不要なスタッフ・お客さま向けの内部ポーリング(4秒間隔)まで裏で起動していた。空席状況ページは他画面と独立させる設計([01]2.5節)に反し、無駄な処理が動いていた。 | AT-50(タイマーの張られ方を計測) | URL判定を早期に1回だけ行い、その結果に応じて内部ポーリングの起動自体をスキップするよう修正した。 |

## 6. セキュリティ確認項目

本システムで最も重大なリスクは「他卓へのなりすまし」と「DBへの直接アクセス」である。以下は導入前に必ず全件実施すること。

| ID    | 確認内容              | 手順                                                                                          | 期待結果                                   |
|-------|-------------------|---------------------------------------------------------------------------------------------|----------------------------------------|
| ST-01 | 他卓へのなりすまし(書込)     | T1のsession_tokenを使い、T2のorder_idに対して注文APIを直接呼ぶ                                               | 403 (SESSION_EXPIRED) が返り、T2に注文が登録されない |
| ST-02 | 他卓へのなりすまし(参照)     | session_tokenを付けずに /orders/{他卓のid}/history を呼ぶ                                              | 403 が返り、他卓の注文内容が取得できない                 |
| ST-03 | 他卓へのなりすまし(呼出)     | T1のsession_tokenでT2のorder_idに対して呼出APIを呼ぶ                                                    | 403 が返り、T2が呼出状態にならない                   |
| ST-04 | session_tokenの再発行 | 会計クリア→再開栓の後、クリア前のsession_tokenでAPIを呼ぶ                                                       | 403 が返る(古いトークンが無効化されている)               |
| ST-05 | DBへの直接アクセス経路      | ブラウザの開発者ツール(Network)で全通信を確認する                                                               | supabase.co への直接通信が1件も存在しない            |
| ST-06 | 鍵の露出              | フロントエンドのJSバンドルを "supabase" "service_role" "eyJ" で検索する                                       | Supabaseの鍵が一切含まれていない                   |
| ST-07 | スタッフAPIの保護        | Bearerトークンを付けずにスタッフAPI(開栓等)を直接呼ぶ                                                            | 401 (UNAUTHORIZED) が返る                 |
| ST-08 | 価格更新APIの保護        | Bearerトークンを付けずに価格更新APIを直接呼ぶ                                                                 | 401 が返り、価格が変わらない                       |
| ST-09 | パッチAPIの保護         | X-Cron-Secretを付けずに daily_clear を呼ぶ                                                          | 401 が返り、卓がクリアされない                      |
| ST-10 | レート制限             | セッション取得APIを1分間に11回以上呼ぶ                                                                      | 11回目以降に 429 (RATE_LIMITED) が返る         |
| ST-11 | 不正なステータス遷移        | served の明細に対して cancelled への変更APIを直接呼ぶ                                                       | 409 (INVALID_STATUS_TRANSITION) が返る    |
| ST-12 | RLSの有効化           | Supabase管理画面で全6テーブルのRLS状態を確認する                                                              | 全テーブルが RLS Enabled になっている              |
| ST-13 | 公開APIからの情報漏洩      | /public/availability のレスポンスボディを "token" "session" "price" "calling" "order_id" 等のキーワードで検索する | いずれもヒットしない                             |
| ST-14 | 公開APIのレート制限       | /public/availability を1分間に31回以上呼ぶ                                                           | 31回目以降に 429 が返り、それ以上の負荷につながらない         |

### ST-01 / ST-06 / ST-13 は特に重要

ST-01が失敗する場合、悪意のある客が他の卓に勝手に注文を追加できる状態にある。ST-06が失敗する場合、ブラウザから直接データベースを読み書きできる状態にあり、全顧客の注文情報が漏洩し得る。ST-13が失敗する場合、認証すら不要な入口から顧客の注文情報が漏れる状態にある。いずれも導入を中止して修正すべき水準の問題である。

## 7. 自動テスト推奨項目(pytest)

| 対象         | テスト内容                                                                                              |
|------------|----------------------------------------------------------------------------------------------------|
| セッション検証    | 正しいtokenで200、誤ったtokenで403、token未指定で403、会計済セッションで403となること                                           |
| ステータス遷移    | pending→served / served→pending / pending→cancelled が成功し、served→cancelled と cancelled→任意 が409となること |
| 金額計算       | 参考小計が単価×数量の合計と一致し、cancelled明細が除外されること。店頭メニューの記載額と1円もずれないこと                                         |
| 価格スナップショット | products.price を更新しても、既存の order_items.price と参考小計が変化しないこと(AT-38の自動化)                               |
| 開栓の排他制御    | 同一卓への連続開栓で2回目409となること                                                                              |
| カスタム明細     | 手入力した税込価格がそのまま小計に反映されること                                                                           |
| 呼び出し       | reasonの列挙値検証、連打時にcall_eventsが増えないこと、解除でresolved_atが入りstatusがActiveのままであること                         |

## 8. 実験導入時の評価項目

本システムの目的は[00]1章のとおり「顧客体験の向上」「スタッフ負荷を増やさないこと」「接客の価値を守ること」である。導入後2〜4週間を目安に、以下を確認して継続/改修/中止を判断する。

| 観点      | 確認方法                                        | 判断の目安                                      |
|---------|---------------------------------------------|--------------------------------------------|
| 顧客体験    | 1卓あたりの注文点数・追加注文の回数を導入前後で比較する                | 追加注文が増えていれば、注文しやすさの改善が実現できている              |
| スタッフ負荷  | スタッフへのヒアリング(操作が増えていないか、巡回が減ったか)             | 「楽になった」という評価が得られること。「操作が増えた」場合は該当機能の見直しが必要 |
| 接客の質    | 会話の量・内容が変わっていないかをヒアリングする                    | 巡回が減った分、ご案内やフレーバーの相談に時間を割けていること            |
| 呼び出しの実態 | call_events を理由別・時間帯別に集計する                  | 「炭の交換」が特定時間に集中する等の傾向を把握し、備品配置の改善に活かす       |
| 対応の速さ   | call_events の resolved_at - called_at を集計する | 呼び出しから対応までが極端に長い事例が常態化していないこと              |
| 安定性     | 営業中のエラー発生・問い合わせ件数を記録する                      | 客からの「使えない」という申告が常態化していないこと                 |
| 運用の定着   | 会計クリア漏れ(日次バッチでの強制クリア)の発生頻度                  | 頻発する場合は、クリア操作の導線を見直す                       |

## 9. 変更履歴

| 版          | 主な変更内容                                             |
|------------|----------------------------------------------------|
| V1.0 (FIX) | 新規作成。受入テスト25件、セキュリティ確認10件、自動テスト推奨項目、実験導入時の評価項目を定義。 |

| 版    | 主な変更内容                                                                                                                                                                               |
|------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| V1.1 | 価格の税込保持に合わせて金額関連のテスト観点を更新。                                                                                                                                                           |
| V1.2 | 呼び出し・価格更新・ポーリング停止・JWT12時間に対応するテスト17件(AT-29～AT-45)を追加。セキュリティ確認に呼出のなりすまし・価格更新APIの保護を追加。実験導入時の評価に接客の質と呼び出しログの活用を追加。現在の実施状況を明記。                                                          |
| V1.3 | プロトタイプに対して画面ロジックの範囲でAT-01～AT-42相当を先行実施(1.1・1.2節)。実施の過程で2件の不具合(セッション失効判定の優先順序、価格入力 of 整数検証)を発見しプロトタイプを修正。副次的にシナリオ常の達成表示を「一度経験したら覚えておく」方式に統一。                                          |
| V1.4 | 空席状況(PUB-001)に対する受入テスト8件(AT-46～53)・セキュリティ確認2件(ST-13・14)を追加(5章・6章)。情報漏洩の確認(AT-51・ST-13)を特に重要な項目として明記。プロトタイプへの実装・実施の過程で1件の不具合(単独ページ表示時に不要な内部ポーリングが動いていた)を発見・修正(5.1節)。セクション番号を1つずつ繰り下げ。 |